

Marketing Agent Dashboard: Codebase Guide

How the dashboard, its backend and the agent controls fit together, what every part of the code does, and how to run, test and extend it.

Repository	Marketing_Agent (folders dashboard/ and dashboardbackend/)
Frontend	Next.js 15 (App Router), React 19, TanStack Query 5, supabase-js 2
Backend	Python, FastAPI, asyncpg, PyJWT, httpx
Data & auth	Supabase (Postgres + Auth)
Agent control	Pipeline control API on Render, applied by the agent on the office machine
As of	7 October 2026, commit 2a16577

Contents

1. What this project is
2. Architecture
3. Repository layout
4. Running it locally
5. Sign-in, roles and security
6. The pages
7. Frontend internals
8. Dashboard backend (FastAPI)
9. How the data is derived
10. Agent Start / Stop
11. User management API
12. Tests
13. Environment variables
14. Extending the code
15. Known limitations and next steps

1. What this project is

This repository is the web dashboard for the AI marketing agent. The agent itself lives in a separate repository (Marketing-AI-Agent) and runs on an office machine: it finds leads, drafts and sends outreach emails, classifies replies, drafts follow-ups and writes blog posts. Everything it produces is stored in Supabase Postgres. People approve emails in Slack.

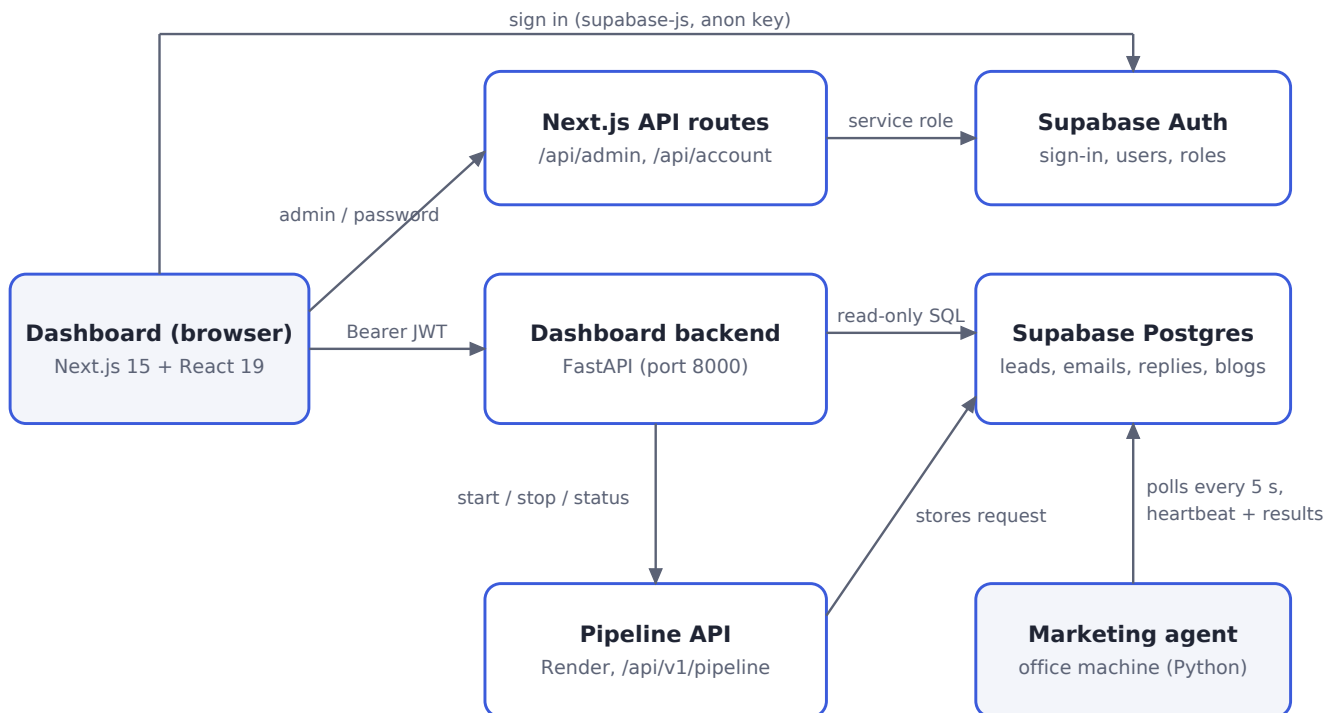
The dashboard lets the team see that work and control the agent:

- **Dashboard:** start or stop the agent, see lead totals, lead sources and the full lead list.
- **History:** every email sent and every reply received.
- **Positive Leads:** leads whose latest reply is interested, uncertain (needs review) or a question, with how long each has been waiting for an answer.
- **Blogs:** blog posts and where they were published.
- **Users** (admins only): create employees, reset passwords, make admins, remove accounts.
- **Profile:** who is signed in, and changing your own password.

The project has two parts that run separately:

Part	Folder	What it does
Dashboard	dashboard/	Next.js app. Renders every page in the browser, signs users in with Supabase Auth, and has a few server-side API routes for user management (they hold the Supabase service-role key).
Dashboard backend	dashboardbackend /	FastAPI service. Verifies the user's Supabase token on every call, reads leads, emails, replies and blogs from Postgres (read-only), and forwards Start/Stop to the pipeline API.

2. Architecture



Four kinds of traffic leave the browser:

- **Sign-in** goes straight to Supabase Auth through supabase-js with the public anon key. The session (access token + refresh token) is kept by supabase-js in the browser.
- **Data** (leads, emails, replies, blogs, agent status) goes to the FastAPI backend with `Authorization: Bearer <access token>`. The backend verifies the token, then runs SQL against Postgres.
- **User management and password changes** go to the dashboard's own Next.js API routes. They run on the server with the Supabase service-role key, which never reaches the browser.
- **Agent Start/Stop** goes to the FastAPI backend, which calls the pipeline API on Render with a secret token. The office machine is behind the office router, so nothing can call it directly: the pipeline API stores the request in the database and the agent polls for it every 5 seconds.

Design choices worth knowing:

- The FastAPI backend never writes to the agent's tables. The agent's services are the only writers.
- Roles live in Supabase `app_metadata`, which only the server (service role) can change. Users can edit their own `user_metadata` (their name), but that is never trusted for permissions.
- Every page is a client component. Pages are guarded in the browser for convenience, but every API checks the token again, so the guard is not the security boundary.

3. Repository layout

Path	Purpose
dashboard/app/layout.js	Root HTML: fonts, page title template, and a tiny script that applies the saved light/dark theme before first paint.
dashboard/app/page.js	Redirects / to /dashboard.
dashboard/app/login/page.js	Sign-in page (renders LoginView).
dashboard/app/(app)/layout.js	Wraps every signed-in page in AppShell (auth guard, top bar, data and drawer providers).
dashboard/app/(app)/error.js	Error boundary: a crash inside a page shows a “Something went wrong” card and keeps the top bar.
dashboard/app/(app)/*/page.js	One thin file per page (dashboard, history, positive-leads, blogs, users, profile) that sets the title and renders its View component.
dashboard/app/api/	Server-only routes: admin/users, admin/users/[id], account/password.
dashboard/components/	All UI: one *View per page, AppShell, DataProvider, DrawerProvider + drawerKinds, ConfirmDialog, shared ui.js pieces, Icon, FormattedContent.
dashboard/core/api.js	Every call to the FastAPI backend (apiFetch + one function per endpoint).
dashboard/core/auth.js	Everything about sign-in: session, isAdmin, signIn/signOut, authFetch for the app's own /api routes.
dashboard/core/admin.js	Client calls for the admin user routes.
dashboard/core/format.js	Date formatting, badge colours (toneOf), source labels, reply-label names.
dashboard/core/supabase.js	The single browser Supabase client (URL + anon key).
dashboard/core/server/supabaseAdmin.js	Server-only helpers: service-role client, getCaller, requireAdmin, error wrapper.
dashboard/app/globals.css	All styling, including light and dark themes via data-theme on <html>.
dashboardbackend/app/main.py	FastAPI app: CORS, /health, /auth/me, includes the data and agent routers.
dashboardbackend/app/auth.py	Verifies Supabase JWTs (JWKS or HS256 secret) and rejects removed users.
dashboardbackend/app/data.py	Read-only SQL routes for leads, emails, replies, blogs.
dashboardbackend/app/agent.py	Start/Stop/status, forwarded to the pipeline API.
dashboardbackend/tests/	pytest suites for auth, data and agent routes.
dashboardbackend/sample_data.sql	Sample rows (all *.example domains) to try the dashboard; includes its own cleanup.

4. Running it locally

Backend (Python 3, from dashboardbackend/):

```
python -m venv .venv && source .venv/bin/activate
pip install -r requirements.txt
# create .env with the variables in section 13
uvicorn app.main:app --reload --port 8000
pytest
```

Dashboard (Node 18+, from dashboard/):

```
npm install
# create .env.local with the variables in section 13
npm run dev          # http://localhost:3000
```

Notes:

- Do not run `npm run build` while `npm run dev` is running: both write to `.next` and the dev server starts returning 500 errors.
- uvicorn's `--reload` only watches Python files. After editing `.env`, restart the backend.
- The backend creates its Postgres connection pool on the first request, so a wrong `DATABASE_URL` shows up as an error on the first data call, not at startup.
- To see data without the agent, run `sample_data.sql` in the Supabase SQL editor (it needs the agent's migrations 0002, 0005 and 0006).

5. Sign-in, roles and security

Signing in

- LoginView calls `supabase.auth.signInWithPassword`. There is no self-service sign-up or password reset: an admin creates accounts.
- AppShell (around every signed-in page) reads the session. No session: redirect to `/login`. Otherwise the page renders immediately and `GET /auth/me` runs in the background; if the backend rejects the token the user is signed out, and if the backend is unreachable an “offline” card with Retry is shown.
- The admin flag in the browser comes from `session.user.app_metadata.role`. It only decides whether the Users tab is shown.

How the backend verifies a token (auth.py)

- Asymmetric tokens (ES256, RS256, EdDSA) are checked against the project's JWKS at `<SUPABASE_URL>/auth/v1/.well-known/jwks.json` (keys cached). Legacy HS256 tokens use `SUPABASE_JWT_SECRET`.
- The audience must be authenticated and `exp` and `sub` are required.
- A token whose `app_metadata.removed` is `true` is refused at once, even before it expires.
- Every data and agent route depends on `current_user`, so a missing or bad token gets 401.

Roles

Role	Can do
employee (default)	See every page except Users; start/stop the agent; change their own password.
admin	Everything an employee can, plus: create users, set their passwords, make an employee an admin (or remove admin rights), remove users. Admins cannot change their own role or remove themselves, so at least one admin always remains.

The Next.js API routes re-check the caller on every request: `getCaller` asks Supabase for the user behind the token (with the service-role key), and `requireAdmin` reads the role from that fresh record. A role change therefore takes effect on the server immediately; only the Users tab waits for the person's token to refresh (within an hour or on next sign-in).

Removing a user

Nothing is deleted. The account gets `app_metadata.removed = true` (hidden from the list) and a ban of about 100 years (no sign-in, no token refresh). Both the FastAPI backend and the Next.js routes refuse removed users.

One setting outside the code

In Supabase, **Authentication → Sign In / Providers → “Allow new users to sign up”** must be off. If it is on, anyone holding the public anon key can create an account directly in Supabase and read the dashboard's data as an employee (they still cannot make themselves an admin).

6. The pages

Page	What it shows	Data (backend route)
Dashboard	Agent Control card (Start/Stop, state, current step, last pass, test mode). Lead stat cards (total, awaiting, responded), a “Leads by Source” bar, and the lead table with status and source filter chips.	/agent, /leads/stats, /leads
History	Two tables side by side: emails sent and replies received, each with a total.	/emails/sent, /emails/replies
Positive Leads	Stat cards (positive leads, leads replied, positive rate). Three groups: Positive, Needs review, Questions. The group is kept in the URL (?group=review). Search by name, company or reply text; sort by follow-up, newest, oldest or name. Follow-up column: “We replied”, “Answer queued” or “Waiting N days” (red after 3 days). A note shows replies still being classified.	/leads/positive
Blogs	Total, posted and not-posted counts, and the list of posts with the site each went to.	/blogs
Users	Admins only. Add-employee form (name, email, password), and the user list with Make admin / Remove admin, Reset password and Remove. Non-admins who open the URL see “Only admins can manage users.”	Next.js /api/admin/users
Profile	Name, email and role badge; change-password form (current, new, confirm).	Supabase session; Next.js /api/account/password
Sign in	Email and password. “Forgot your password? Contact your admin.”	Supabase Auth

The detail drawer

Clicking any row (or pressing Enter on it) opens one shared drawer on the right. It shows the item's details, Previous/Next buttons that step through exactly the rows currently visible (respecting filters, search and sort), and links between related items: a lead opens its email conversation, a sent email opens its reply, a reply opens the original email. Those links switch page first when needed. Esc closes it; focus stays inside while it is open and returns to the row afterwards.

7. Frontend internals

AppShell

The auth guard and frame for every signed-in page: checks the session, renders the top bar (tabs, theme toggle, sign-out), and wraps the page in `DataProvider` and `DrawerProvider`.

DataProvider: data loading and caching

- Built on TanStack Query. Each kind of data is a “section”: agent, stats, leads, sent, replies, blogs, positive. Each maps to one function in `core/api.js`.
- A page calls `useSection('leads')` and gets `{ status: 'loading' | 'ready' | 'error', data, reload }`. Sections load on first use, are shared between pages, and refetch in the background after 30 s (on window focus or reconnect). Failed requests retry once.
- Data already on screen stays visible if a background refetch fails.
- The agent section polls: every 3 s while a Start/Stop is being applied, otherwise every 10 s.
- It also holds UI state that must survive tab switches: the lead filters and the Positive Leads search and sort.

DrawerProvider and drawerKinds

`DrawerProvider` owns the single drawer: which kind and id are open, loading the detail (cached per item), Previous/Next, keyboard handling and cross-page navigation (`goto(page, kind, id)`). `drawerKinds.js` describes what each kind shows: lead, positiveLead, reviewLead, questionLead, sent, reply, blog. Each kind names the section behind Previous/Next, how to load one item, and how to turn it into rows, an action button and a body.

Shared pieces

File	Contents
<code>ui.js</code>	Badge, StatusBadge, SourceCell, SiteCell, Skeleton, ErrorBox, EmptyBox, CardHead, MetaRow, ViewCell, ExtLink, StatCards, and DataTable (skeleton / error / empty / table in one).
<code>ConfirmDialog.js</code>	<code>useConfirm()</code> : a styled replacement for <code>confirm()/prompt()</code> built on <code><dialog></code> . Returns true/false, or the typed password.
<code>FormattedContent.js</code>	Minimal formatter for email and blog bodies: headings, lists, quotes, paragraphs, and clickable URLs and emails. No HTML from the data is ever injected.
<code>Icon.js</code>	Inline SVG icons by name; unknown names render nothing.
<code>OpenRow.js</code>	Table row that opens the drawer and shows itself as selected.
<code>core/format.js</code>	<code>fmtDate</code> (all times shown in UTC), <code>daysSince</code> , <code>toneOf</code> (badge colours by text), <code>SOURCES</code> , <code>REPLY_LABELS</code> .

Errors from the backend: `apiFetch` throws an `ApiError` with the HTTP status (0 when the server can't be reached) and, when FastAPI sends one, its detail message.

8. Dashboard backend (FastAPI)

Route	Auth	Returns
GET /health	none	{ ok: true }
GET /auth/me	Bearer	id, email, role of the caller
GET /leads	Bearer	All leads, newest first, without contact details. Optional ?status=awaiting responded and ?source=linkedin x other.
GET /leads/stats	Bearer	total, awaiting, responded, bySource
GET /leads/positive	Bearer	positive, review, questions (each ordered for follow-up), repliedLeads, pending
GET /leads/{id}	Bearer	One lead with title, company, URLs, email, the conversation to open, latest reply label and review reason
GET /emails/sent	Bearer	Sent and bounced emails, newest first (no body)
GET /emails/sent/{id}	Bearer	One sent email including its body
GET /emails/replies	Bearer	Replies, newest first (no body)
GET /emails/replies/{id}	Bearer	One reply with body and the original email it answers (or null)
GET /blogs	Bearer	Blog posts, newest first (no content)
GET /blogs/{id}	Bearer	One post including its Markdown content
GET /agent	Bearer	Agent status from the pipeline API
POST /agent/start	Bearer	Requests a start; records the caller's email
POST /agent/stop	Bearer	Requests a stop; records the caller's email

- **Response shape.** Database columns are snake_case; `_plain()` turns each row into camelCase JSON (sent_at → sentAt), with UUIDs and timestamps as strings. Agent responses are camelCased the same way.
- **Numbers.** Leads, emails, replies and blogs get a stable 1-based number (oldest = 1) from `row_number()`, so the UI can show “#012”.
- **Bad ids.** An id that isn't a UUID returns 404, not 500.
- **Connection pool.** `asyncpg` pool (1–5 connections) created on first use with `statement_cache_size=0`, which the Supabase transaction pooler (pgbouncer) requires.
- **CORS.** Origins from `CORS_ORIGINS` (default `http://localhost:3000`); GET and POST only.

9. How the data is derived

All of this is SQL in dashboardbackend/app/data.py over the agent's tables companies, contacts, emails, replies and content_posts.

Concept	Rule
Lead	A contacts row joined to its companies row. Name falls back to the email, then the company name.
Lead source	linkedin if companies.source contains "linkedin"; x if it contains the word "x" or "twitter"; otherwise other.
Lead status	Responded if the contact has any reply that is not out-of-office or a bounce; otherwise Awaiting .
Sent email	An emails row with status sent (shown as Delivered) or bounced (shown as Failed) and a sent time.
Reply subject	"Re: " + the subject of the email it answers.
Blog status	published → Posted; anything else → Not Posted. Site: Dev.to, WordPress or LinkedIn, depending on which URL is set.

Positive Leads

- Each lead is judged on its **latest classified reply written by a person** (out-of-office and bounces are skipped). A later "not interested" replaces an earlier "interested".
- **Needs review**: the classifier recorded low confidence (review_note like "confidence 0.42 < 0.6") and the label is interested, question or not_interested. A doubtful "no" may be a hidden "yes".
- **Positive**: label interested with confidence. **Questions**: label question.
- **Follow-up**: "replied" once an answer to that reply was sent, "queued" if one is approved or sending, otherwise "waiting".
- **Order**: waiting leads first, longest-waiting on top; then the rest, newest reply first.
- **Preview**: the reply text without quoted mail and without a greeting line, on one line, up to 100 characters (the same rules as the agent's reply classifier).
- **pending**: replies not classified yet; the page says they will appear shortly.

10. Agent Start / Stop

The agent runs on the office machine and nothing on the internet can reach it, so control goes through the pipeline API:

```
Dashboard -> POST /agent/start (dashboard backend, checks the user's token)
           -> POST <AGENT_API_URL>/api/v1/pipeline/start Authorization: Bearer
           <AGENT_API_TOKEN>
               body: { "requested_by": "<user email>" }
           -> pipeline API stores the request in Supabase
           -> agent polls every 5 s, applies it, reports state + heartbeat
```

- Start and Stop are **requests**. They return at once; the agent applies them within about 5 s (a stop can take up to 30 s while the current step winds down). The dashboard polls status every 3 s until inSync is true.
- While running, the agent does passes 30 minutes apart: Gmail inbox → replies → send approved → follow-ups → lead discovery → blog (at most one post a day). Emails approved in Slack go out within about 20 s.
- While stopped, nothing is searched, drafted, sent or polled. Slack approvals are still recorded and go out after the next start.
- If the office machine is off, a request is kept and applied when it comes back.
- The token is only in the backend's environment; the browser never sees it.

What the card shows

Condition	Badge	Button and note
Office machine not reporting (heartbeat older than 60 s)	Offline	"Office machine offline." plus "It will start when it comes back." if Start was requested. The button still sends requests.
Request not applied yet	Starting... / Stopping...	Button disabled until in sync.
Running	Running	Stop button; the current step (e.g. "Finding leads...") or when the next pass starts.
Stopped	Stopped	Start button.

Under the note the card also shows the last pass (Succeeded, Failed or Stopped, with time), who last started or stopped the agent, "Email sending is off." when sending is disabled, and "Test mode: emails go to the test inbox."

Errors are explained: a missing token gives 503 "AGENT_API_TOKEN is not set", a rejected token or an unreachable API gives 502 with the reason. The HTTP timeout is 60 s because a sleeping Render instance can take close to a minute to wake.

11. User management API (Next.js routes)

These run on the Next.js server with `SUPABASE_SERVICE_ROLE_KEY` (imported with `server-only` so it can never be bundled for the browser). The browser calls them with `authFetch`, which adds the user's token. Any unexpected failure becomes a JSON 500 with a generic message.

Route	Who	What it does
GET /api/admin/users	admin	Lists users (up to 200), hiding removed ones: id, email, name, role, created and last sign-in times.
POST /api/admin/users	admin	Creates a confirmed user from name, email and a password the admin chooses (8+ characters). 409 if the email already has an account.
PATCH /api/admin/users/{id}	admin	{ password } sets a new password; { role: 'admin' 'employee' } changes the role. Not allowed on yourself.
DELETE /api/admin/users/{id}	admin	Marks the user removed and bans them. Not allowed on yourself.
POST /api/account/password	any user	Checks the current password by signing in with it, then sets the new one (8+ characters, different from the current one).

12. Tests

Backend tests run with `pytest` from `dashboardbackend/` (19 tests, all passing). They need no database or network: tokens are signed with a test secret and the database and pipeline API are replaced with fakes.

File	Covers
tests/test_auth.py	Public /health; valid, missing, expired, wrong-audience and badly signed tokens; removed users are rejected.
tests/test_data.py	Data routes need a login; lead filters hide contact details; lead stats; Positive Leads grouping, follow-up order and preview text.
tests/test_agent.py	Agent routes need a login; Start forwards the token and the user's email; status and stop hit the right URLs; a rejected token is explained; a missing token gives 503.

The dashboard has no automated tests yet, and the SQL queries are not tested against a real database.

13. Environment variables

Names only; the values live in `dashboardbackend/.env` and `dashboard/.env.local`, which are not committed.

Variable	Where	Purpose
NEXT_PUBLIC_SUPABASE_URL	dashboard	Supabase project URL (public). The app refuses to start without an http(s) URL.
NEXT_PUBLIC_SUPABASE_ANON_KEY	dashboard	Supabase anon key (public).
NEXT_PUBLIC_API_URL	dashboard	FastAPI backend URL. Default <code>http://localhost:8000</code> .
SUPABASE_SERVICE_ROLE_KEY	dashboard (server only)	Used by the /api routes for user management. Secret.
SUPABASE_URL	backend	Supabase URL, for JWKS (falls back to NEXT_PUBLIC_SUPABASE_URL).
SUPABASE_JWT_SECRET	backend	Only for legacy HS256 projects.
DATABASE_URL	backend	Pooled Postgres connection string. Secret.
CORS_ORIGINS	backend	Comma-separated dashboard origins. Default <code>http://localhost:3000</code> .
AGENT_API_TOKEN	backend	Pipeline API token (PIPELINE_API_TOKEN is accepted too). Secret.
AGENT_API_URL	backend	Pipeline API base URL. Default <code>https://marketing-agent-pipeline-api.onrender.com</code> .

14. Extending the code

A new data route. Write the query in `app/data.py` and return it through `_rows()` or `_one()` (the router already requires a login). Add a one-line function in `core/api.js`, then either register it as a section in `DataProvider.js` (FETCHERS and EMPTY) or call it directly. Add a test with `_rows` monkeypatched, as in `tests/test_data.py`.

A new page. Add `app/(app)/<name>/page.js` that sets `metadata.title` and renders a `View` component, add the tab to `TABS` in `AppShell.js`, and build the view from `useSection`, `DataTable` and `OpenRow`.

A new kind in the drawer. Add an entry in `drawerKinds.js` with `section`, `list`, `load` and `describe`, then use `<OpenRow kind="...">` in the table.

Admin-only server logic. Start the route handler with `requireAdmin(request)` and wrap it in `handle()`.

15. Known limitations and next steps

Area	Issue	Suggestion
Scale	Every list route loads the whole table and filtering happens in Python; there is no pagination. <code>/leads/{id}</code> numbers every contact to return one row.	Add pagination and filter in SQL; store stable numbers in a column.
Users	The user list reads at most 200 users.	Page through Supabase's admin list.
Security	Supabase public sign-up must be off (section 5). Any signed-in user can start or stop the agent.	Verify the setting; restrict Start/Stop to admins if wanted.
Backend	The connection pool is created lazily (two first requests at once can create two) and is never closed.	Create and close it in a FastAPI lifespan handler.
Tests	No dashboard tests; SQL not tested against a database.	Run the queries against <code>sample_data.sql</code> in CI.
Docs	Some comments and the backend README still mention <code>eval/</code> paths and <code>pipeline-api.md</code> , which was removed from this repo (it is in the agent repo). <code>Dashboard-Guide.pdf</code> was deleted in commit <code>f874538</code> .	Update the references.
Dependencies	<code>pytest</code> and <code>httpx</code> are in the production requirements; versions are not pinned.	Split into <code>requirements-dev.txt</code> and <code>pin</code> .
UI	The show/hide password field is repeated in three components and the 8-character minimum in several places. Lead notes are always empty (the backend has no notes yet). All times are shown in UTC.	One <code>PasswordInput</code> component and one constant.
Agent	Start/Stop works end to end, but no full pass had completed when this guide was written.	Run a full pass in test mode and check "Last pass".